

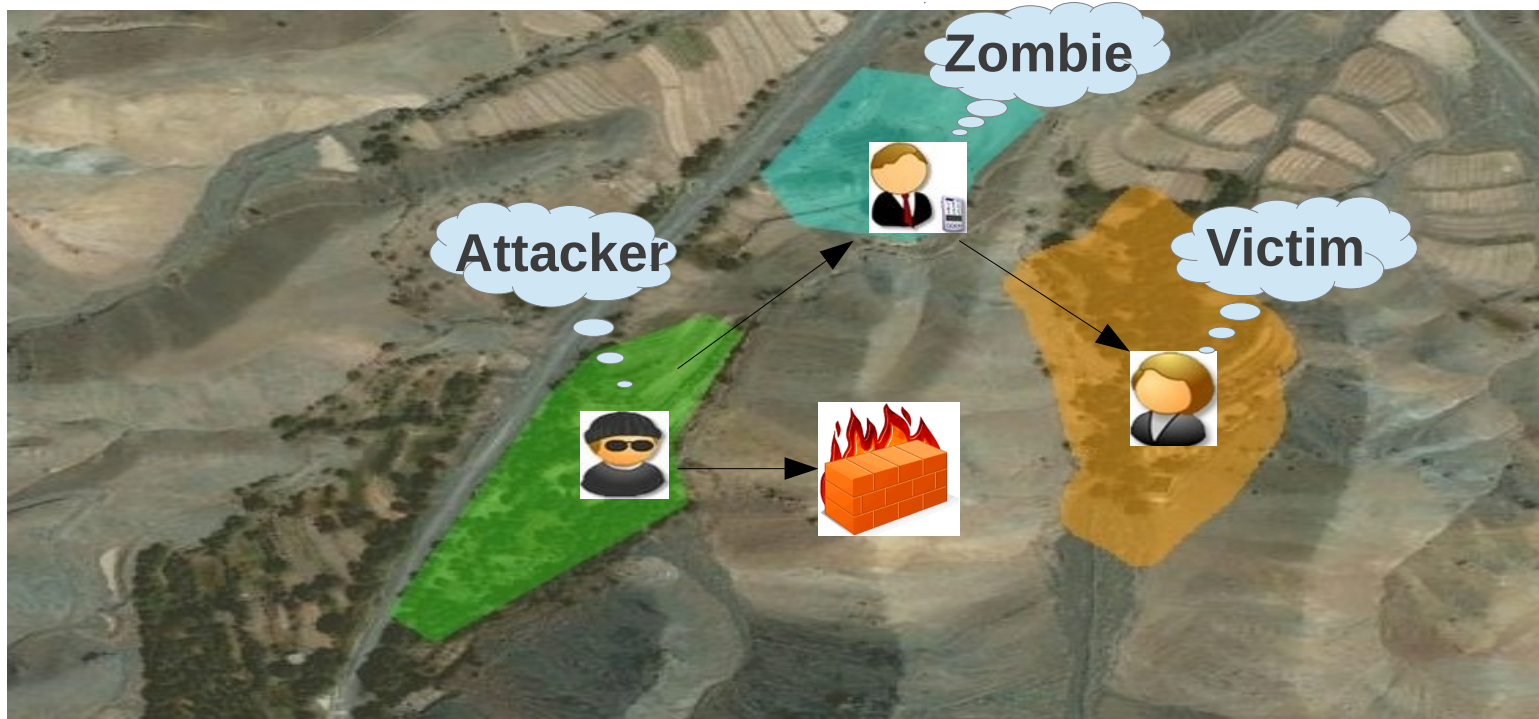
Advanced Network Inference Techniques Based on Network Protocol Stack Information Leaks

Roya Ensafi
October 2013

Still A Peach Attacker

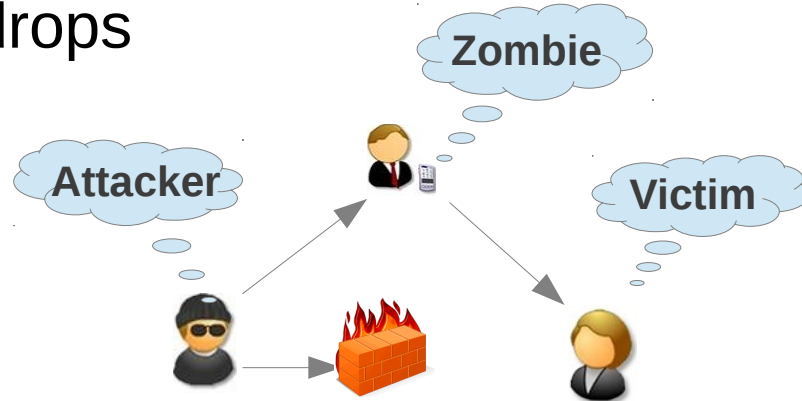


Still A Peach Attacker



What if we could?

- ö Scan a firewall port or a hidden machine
- ö Infer IP-based trust relationships
- ö Infer communication constraints
- ö Infer imposed geographical (dis)-connectivity
- ö Infer intentional packet drops
- ö ...



Outline

- ö Background knowledge
- ö Brief overview of USENIX'10 paper
 - ↻ Idle Port Scanning and Non-interference Analysis of Network Protocol Stacks
 - ↻ SYN backlog idle scan
- Overview PAM'13(Submitted) paper
 - ↻ Detecting Bi-Directional Intentional Packet Drops Using Idle Scans
 - ↻ Real Data examples
- ö Future work

Model checking network stack

- Is there a way we automate finding inference attacks...
- Create transition system of network protocol stack
- Check all possible scenarios for non-interference property

Shared (limited) resources



- Global IPID variable
 - Global counter that incremented by one any time packet is sent out.
 - Unique numbers used for fragmentations.
 - At anytime, it shows number of packets has sent to other destinations.
- RST rate limiting counter
 - A machine limits the number of RST packets that it will send in a given time period.
- SYN backlog/cache
 - A cache for holding half-open TCP connections
 - Waiting for proper ACK or RST to drop it

Port & port scanning

Host1

SYN cache = 0

RST counter = 1

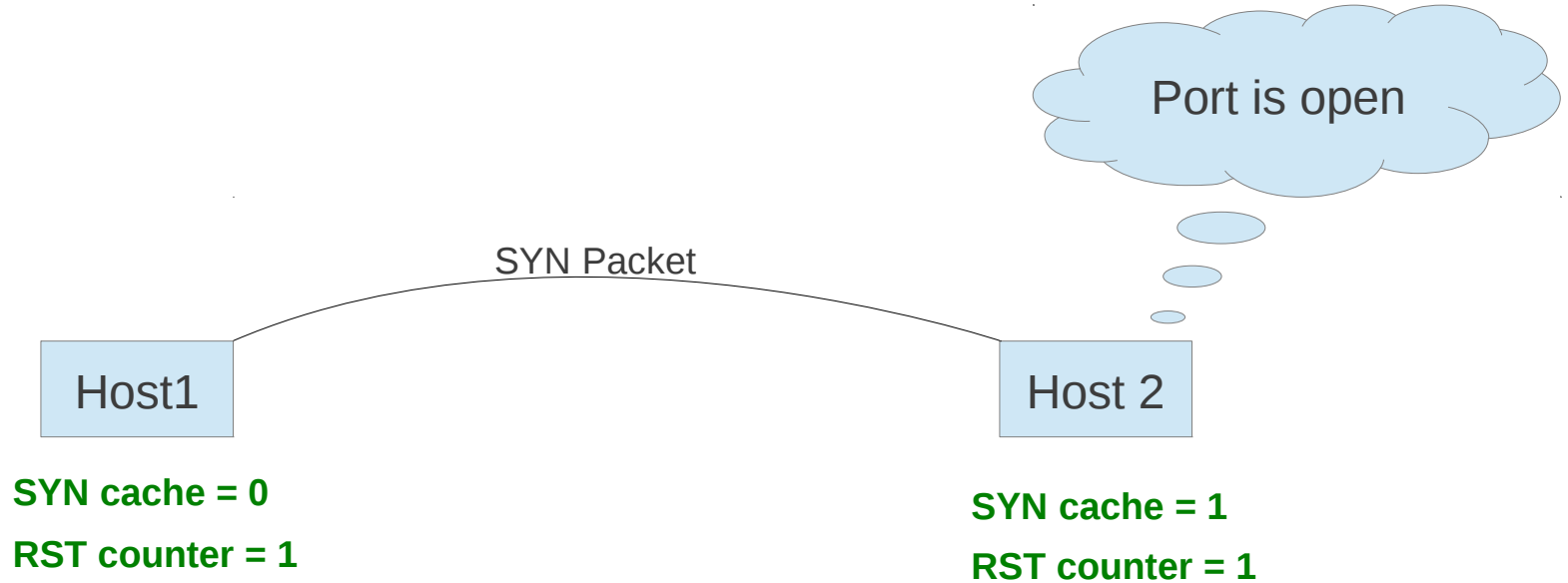
Host 2

SYN cache = 0

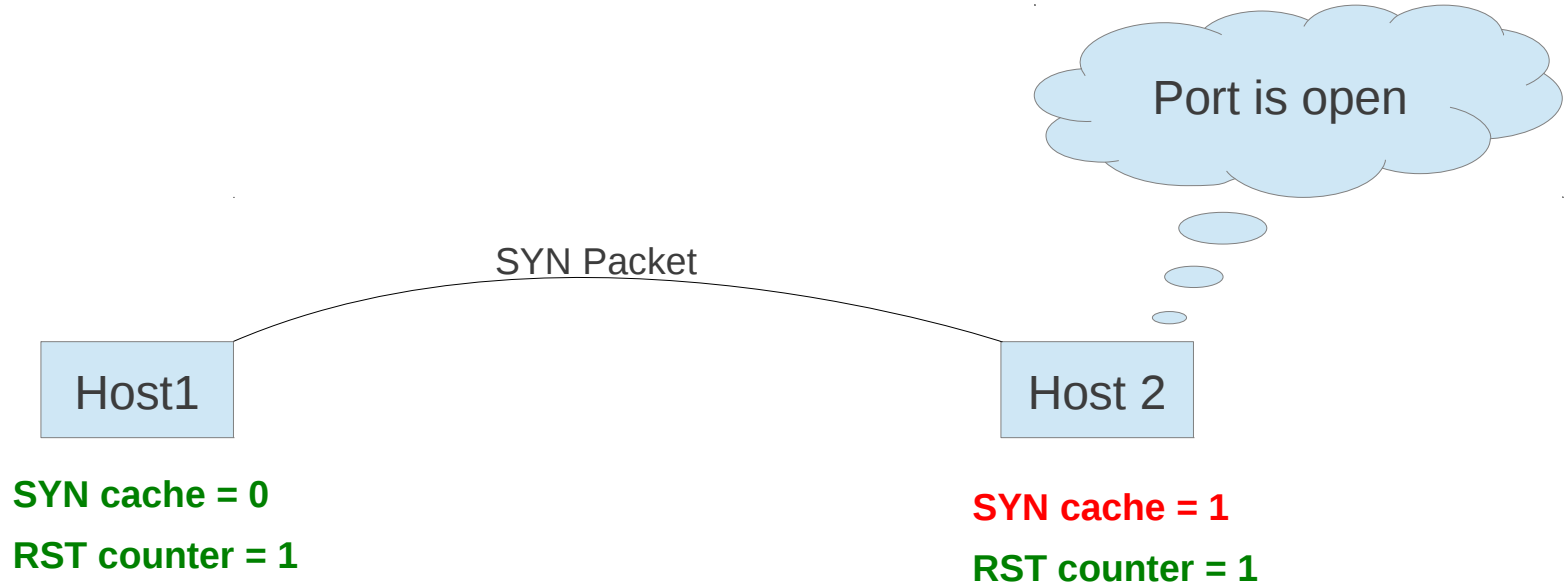
RST counter = 1



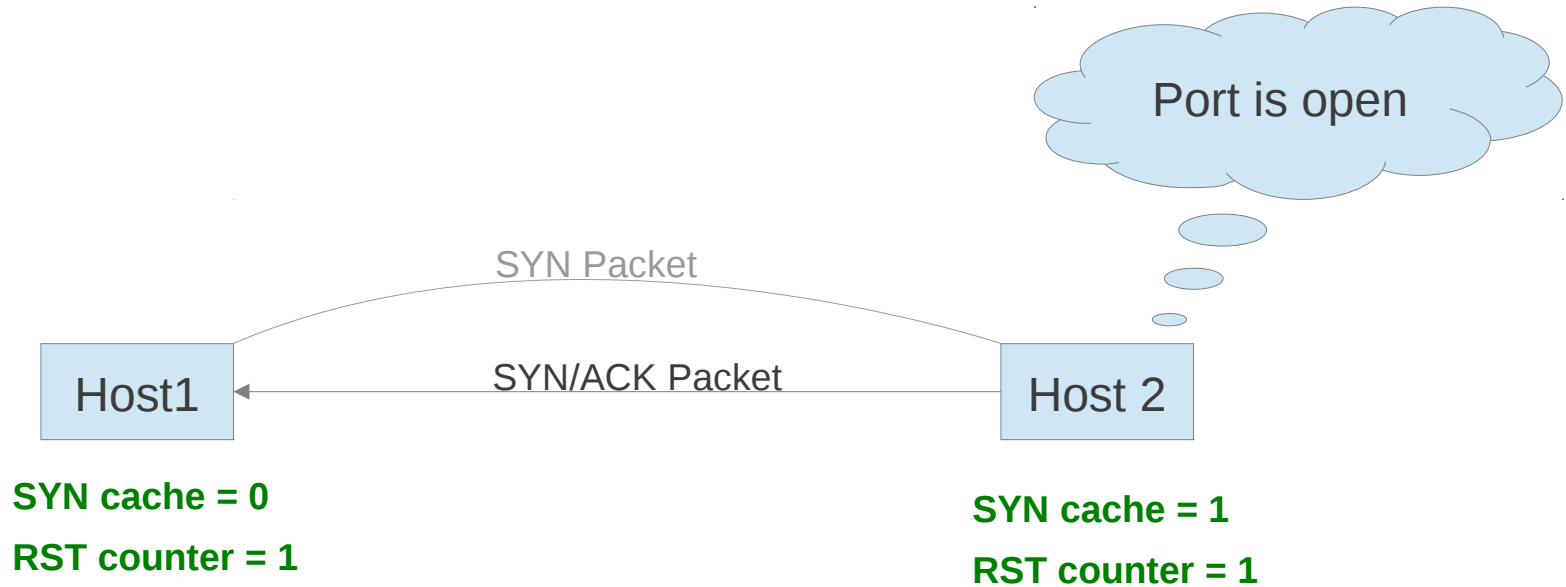
Port & port scanning



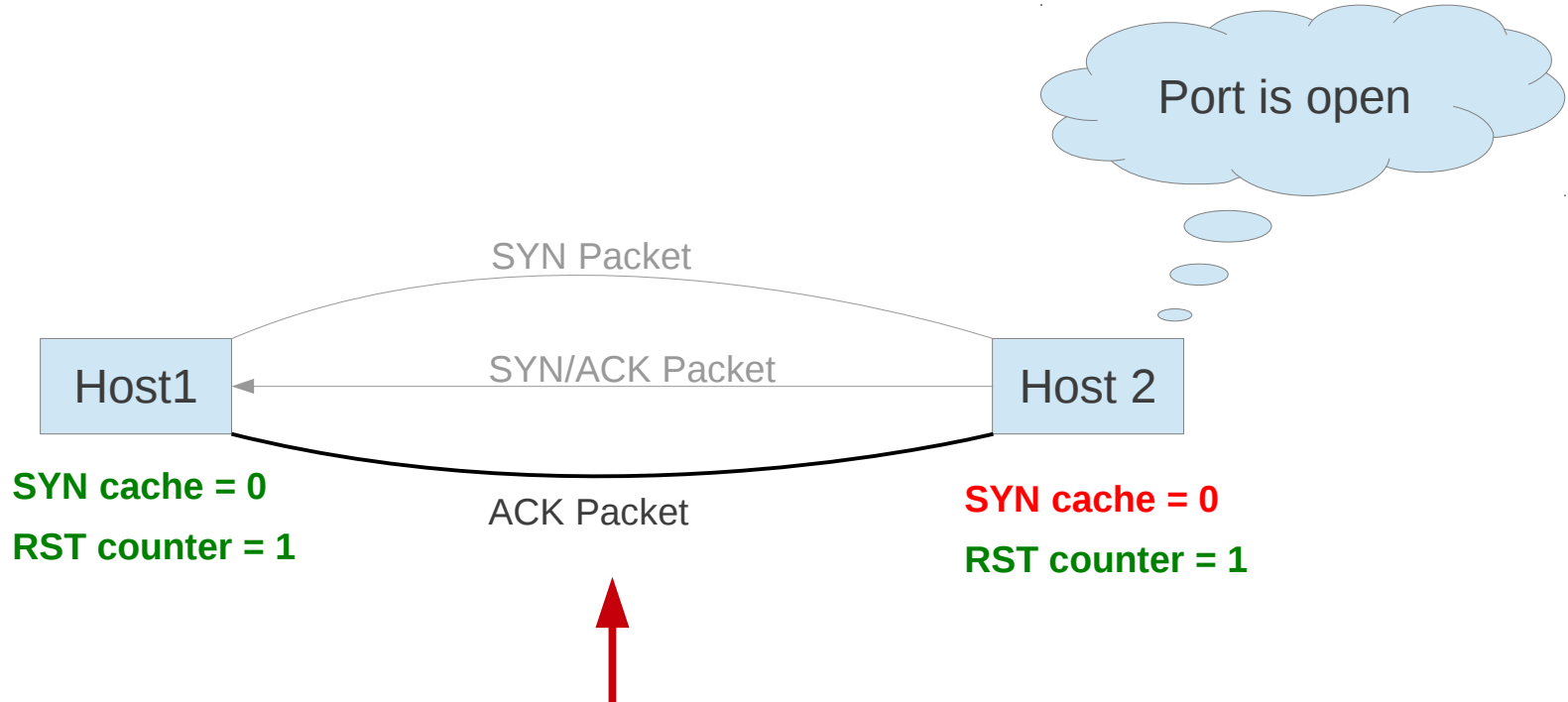
Port & port scanning



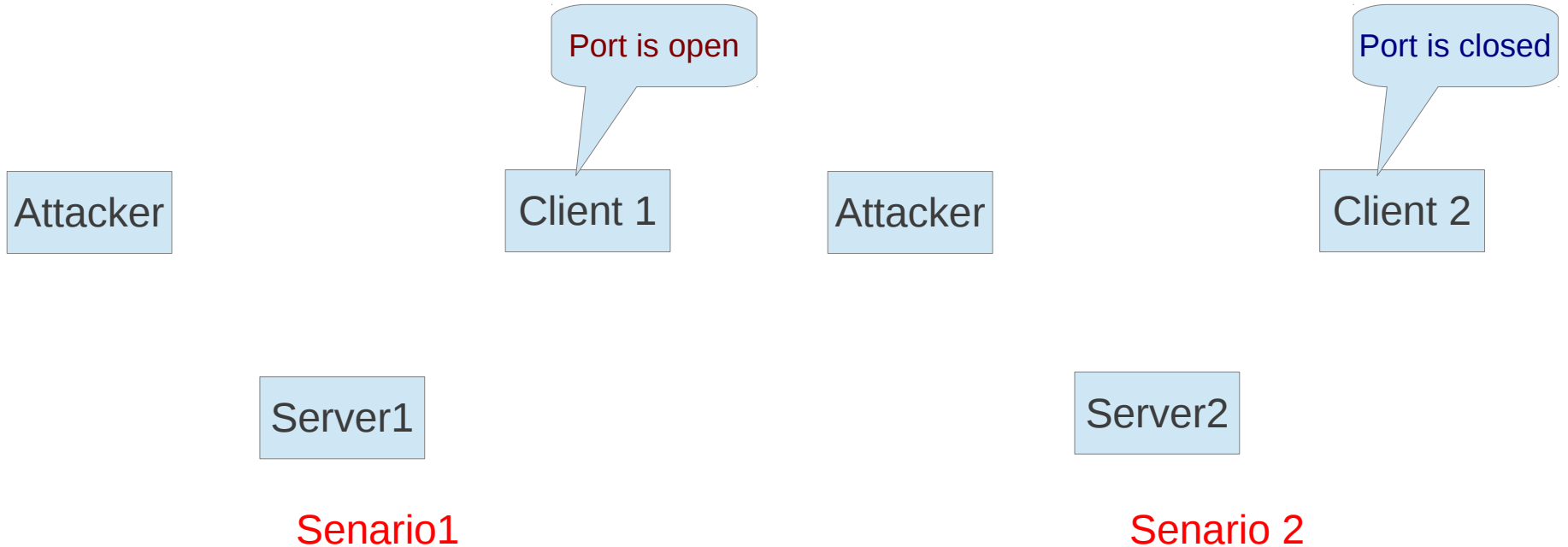
Port & port scanning



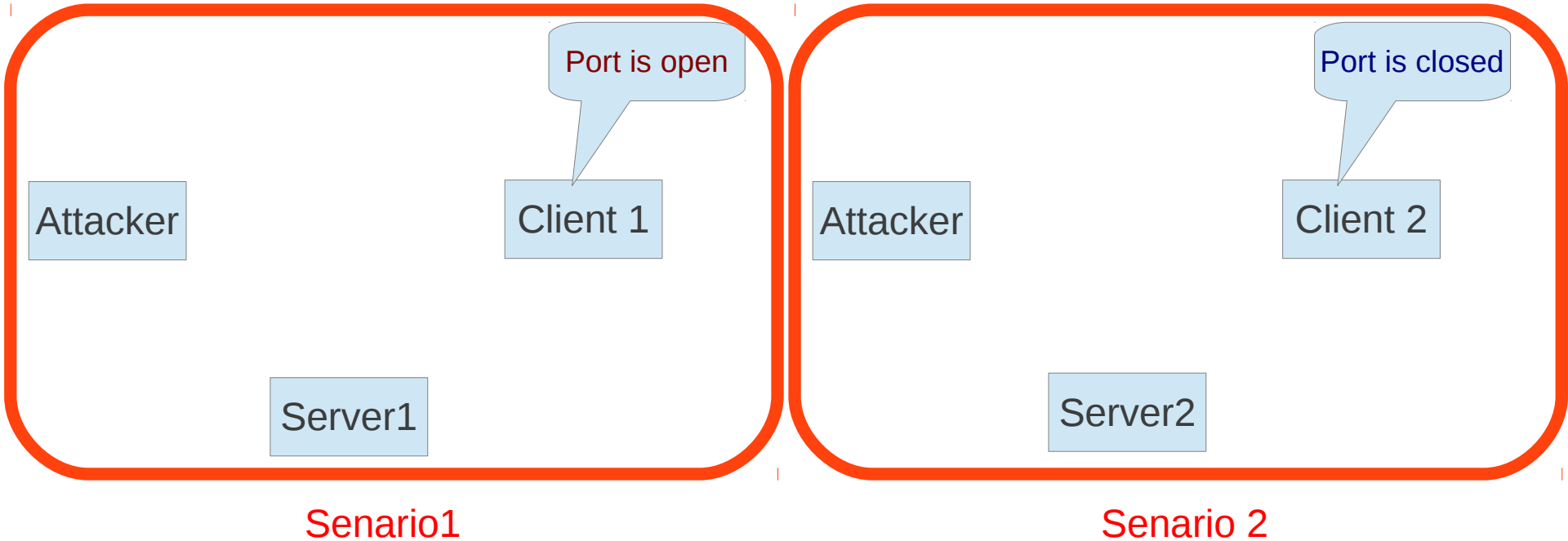
TCP hand shake



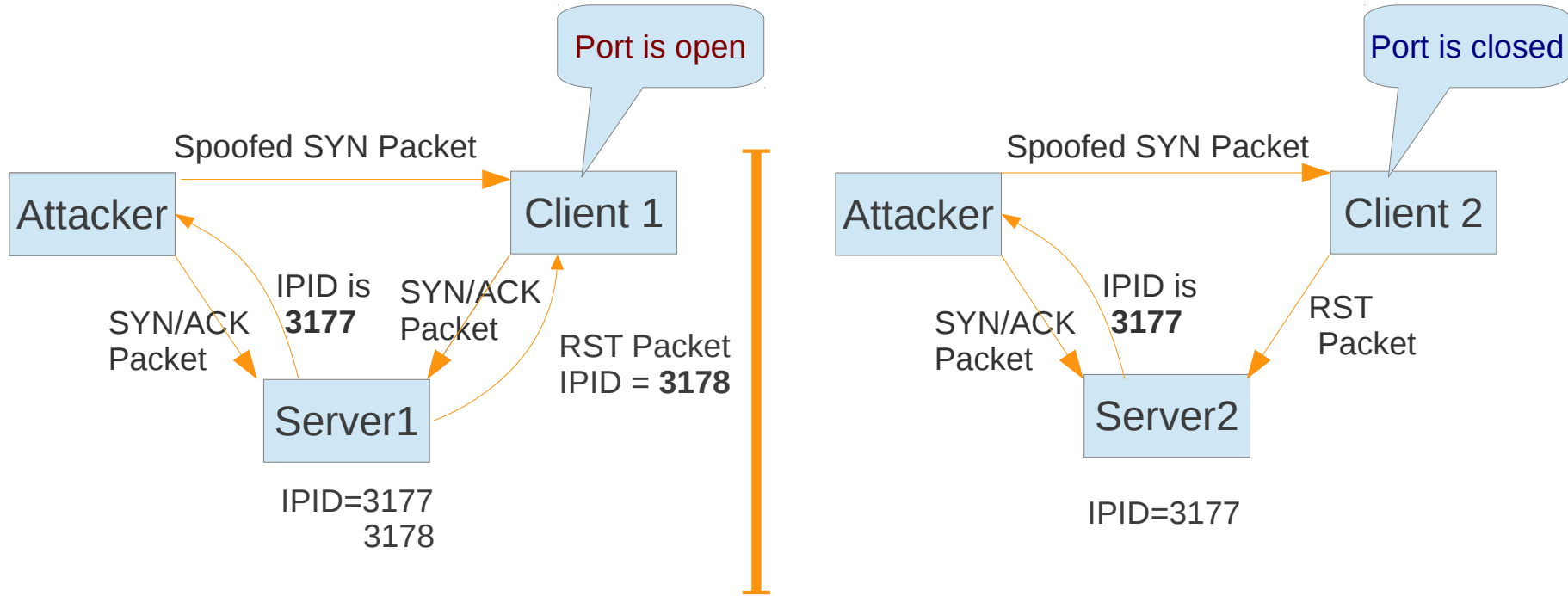
Idle scanning



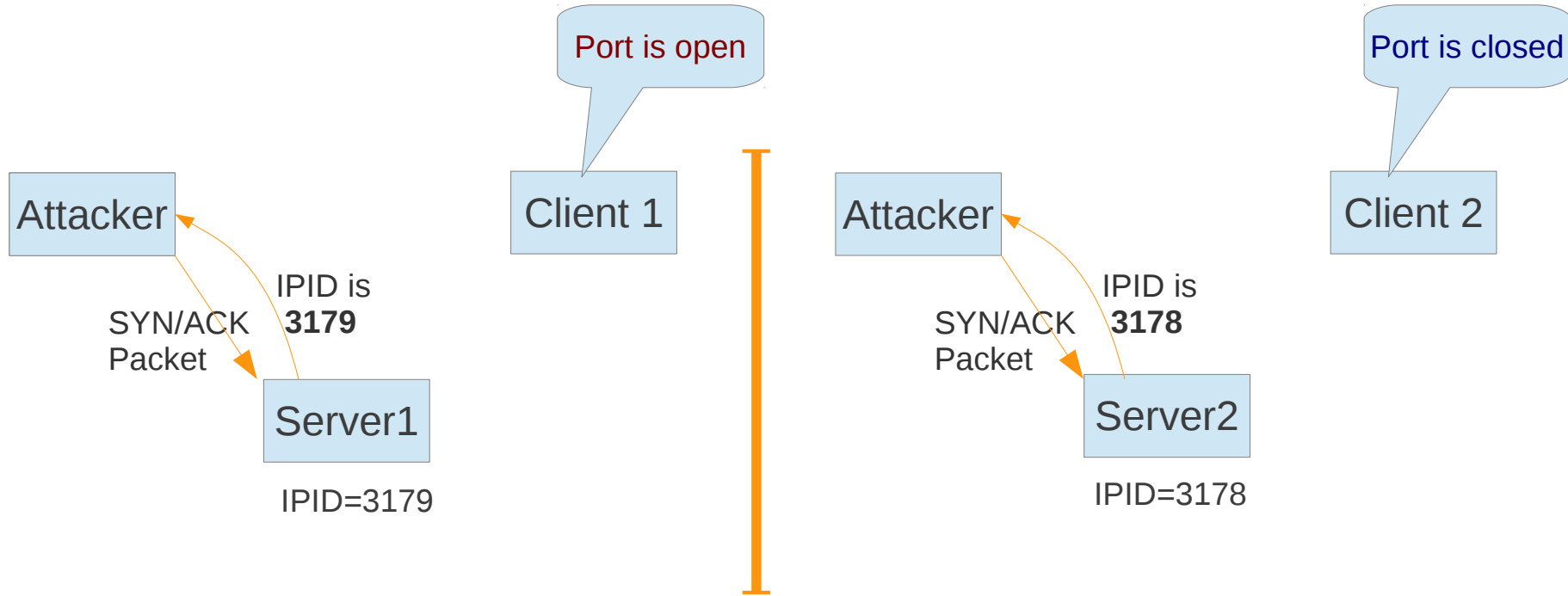
Idle scanning



IPID idle scanning

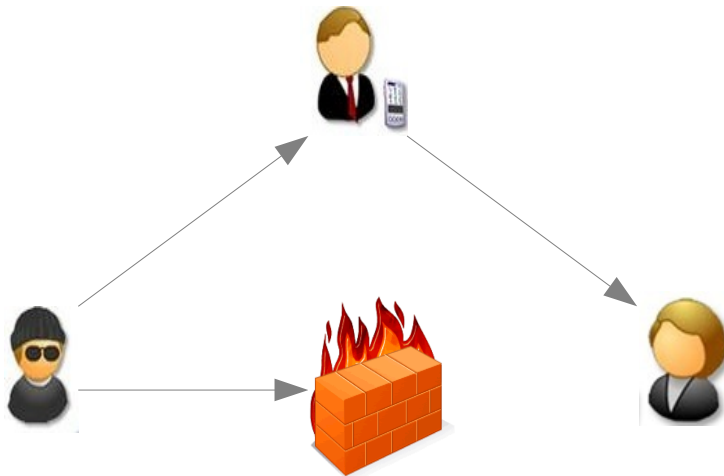


IPID idle scanning

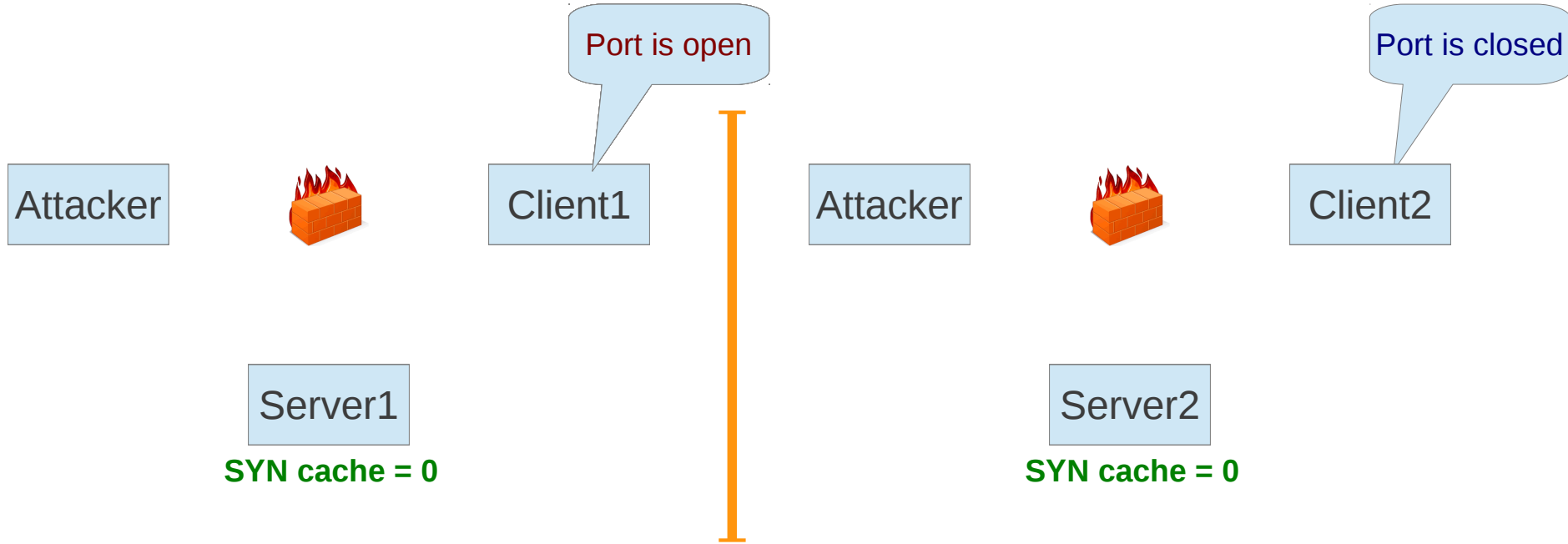


Idle scanning with brick wall

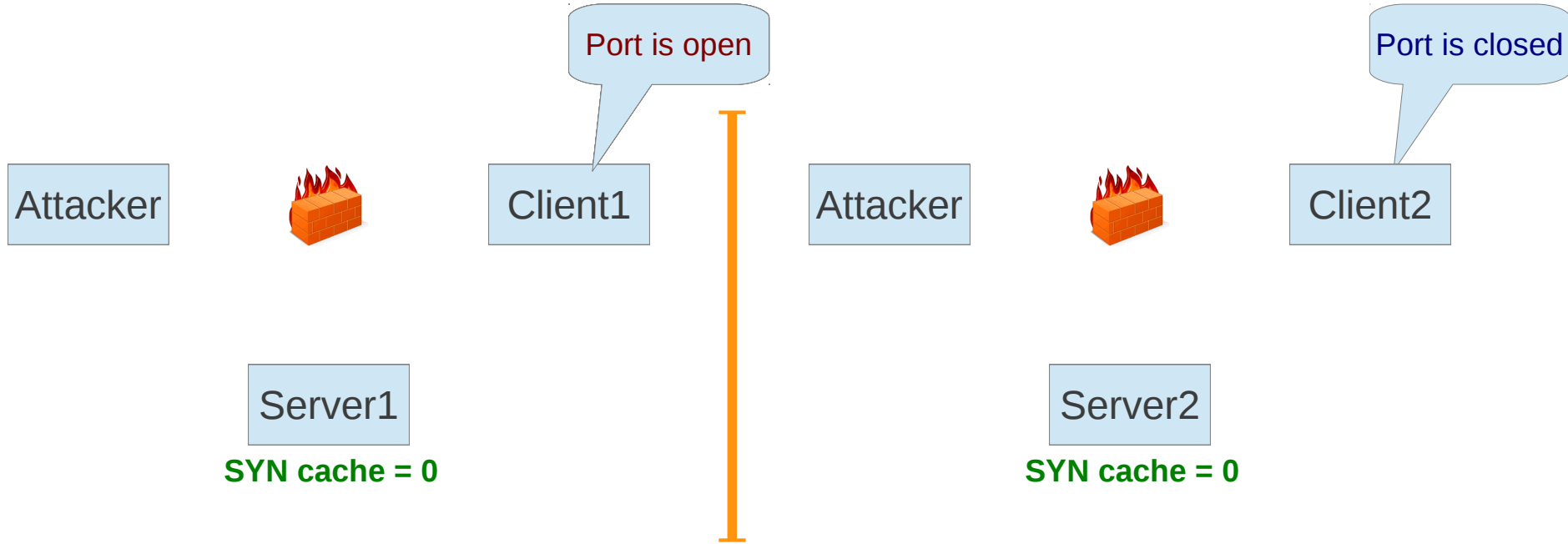
First idle scan that allows an attacker to scan firewalled networks and ports and infer trust relationships **without routing any packets to the victim**



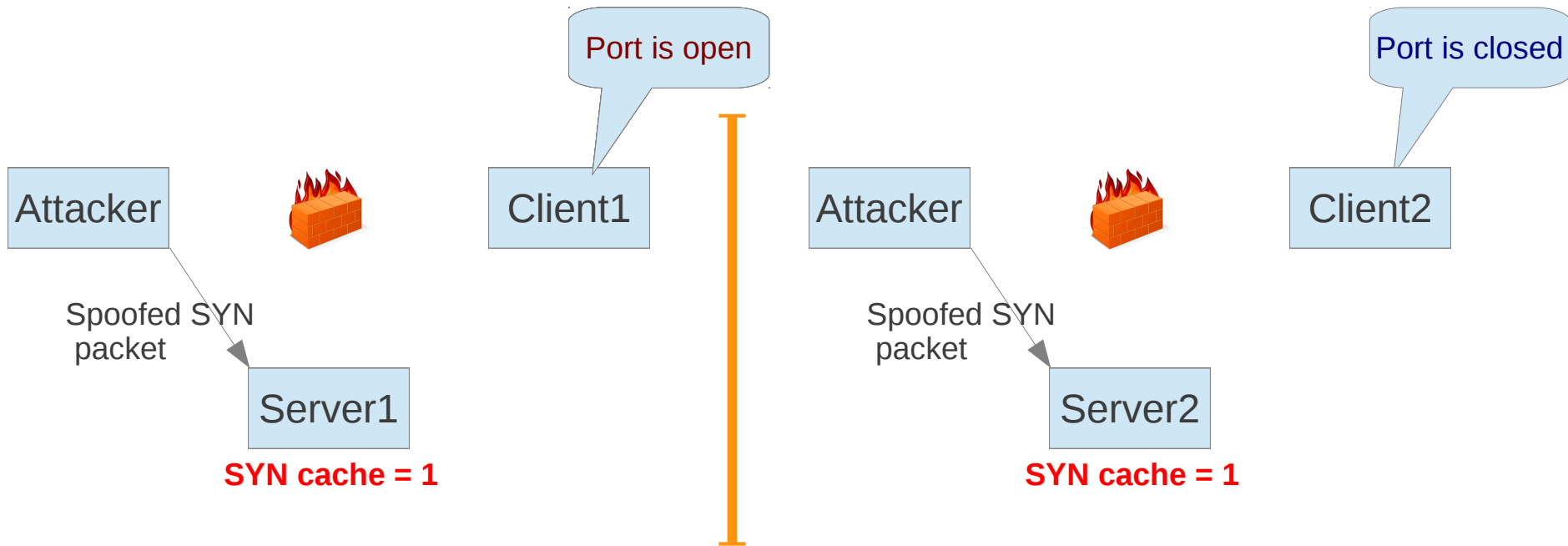
SYN backlog idle scanning



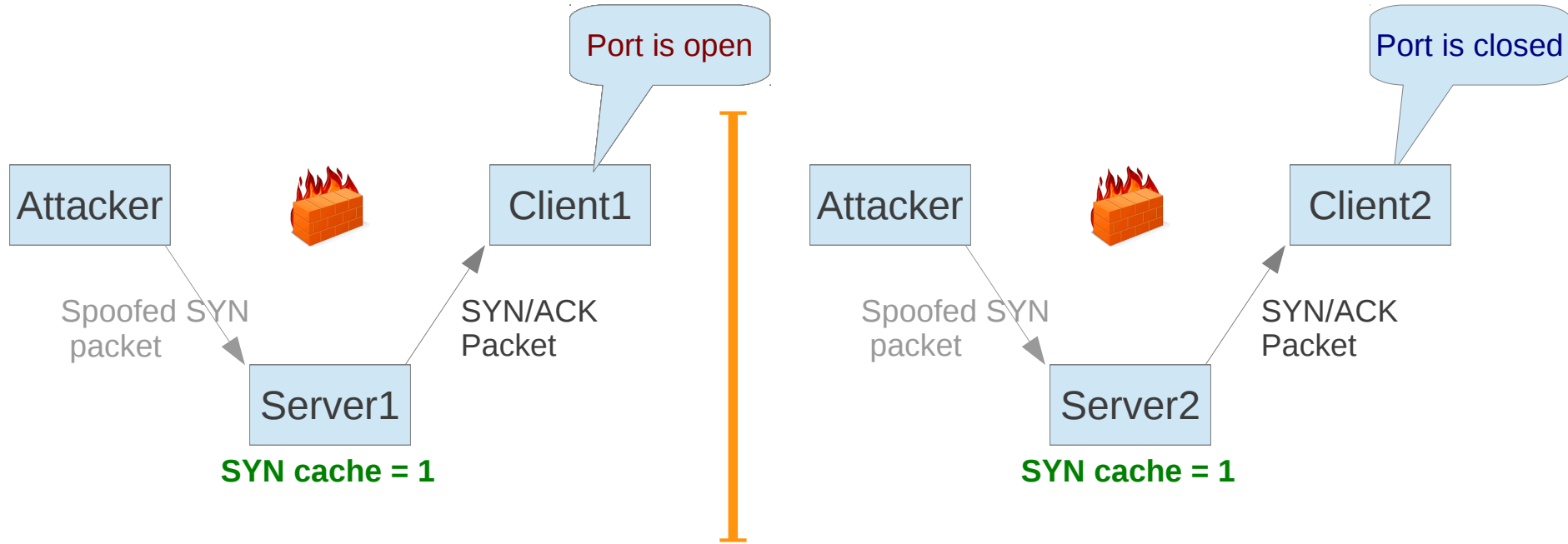
SYN backlog idle scanning



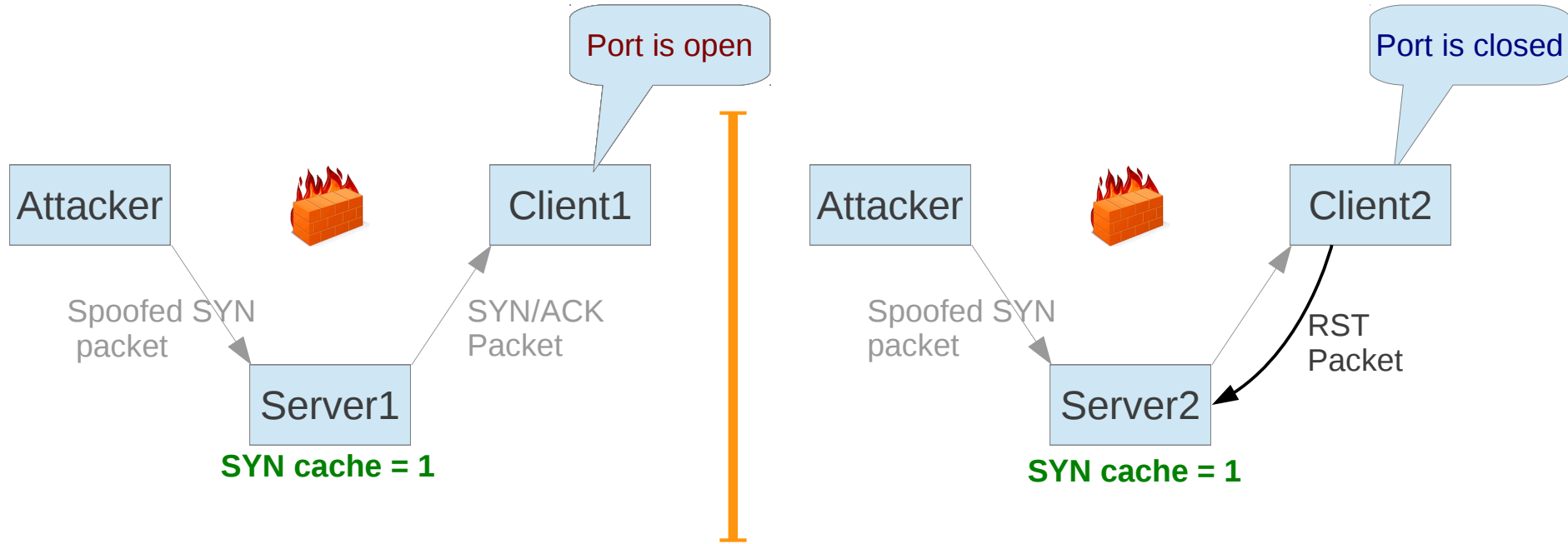
SYN backlog idle scanning



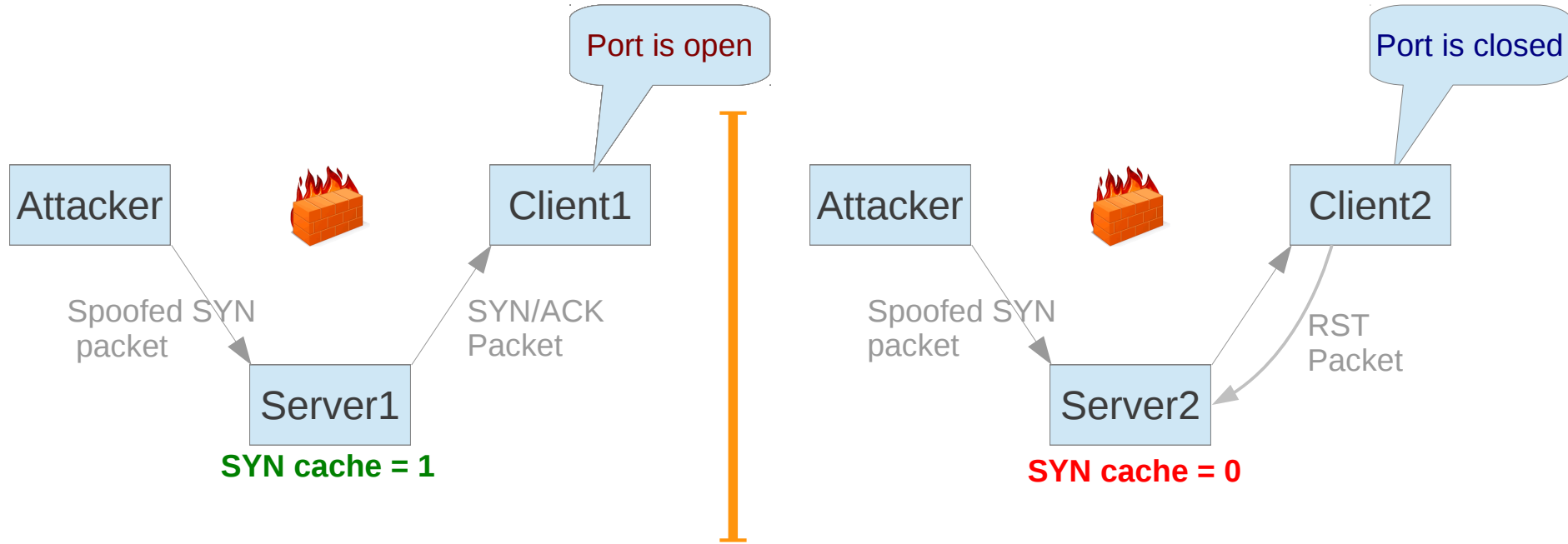
SYN backlog idle scanning



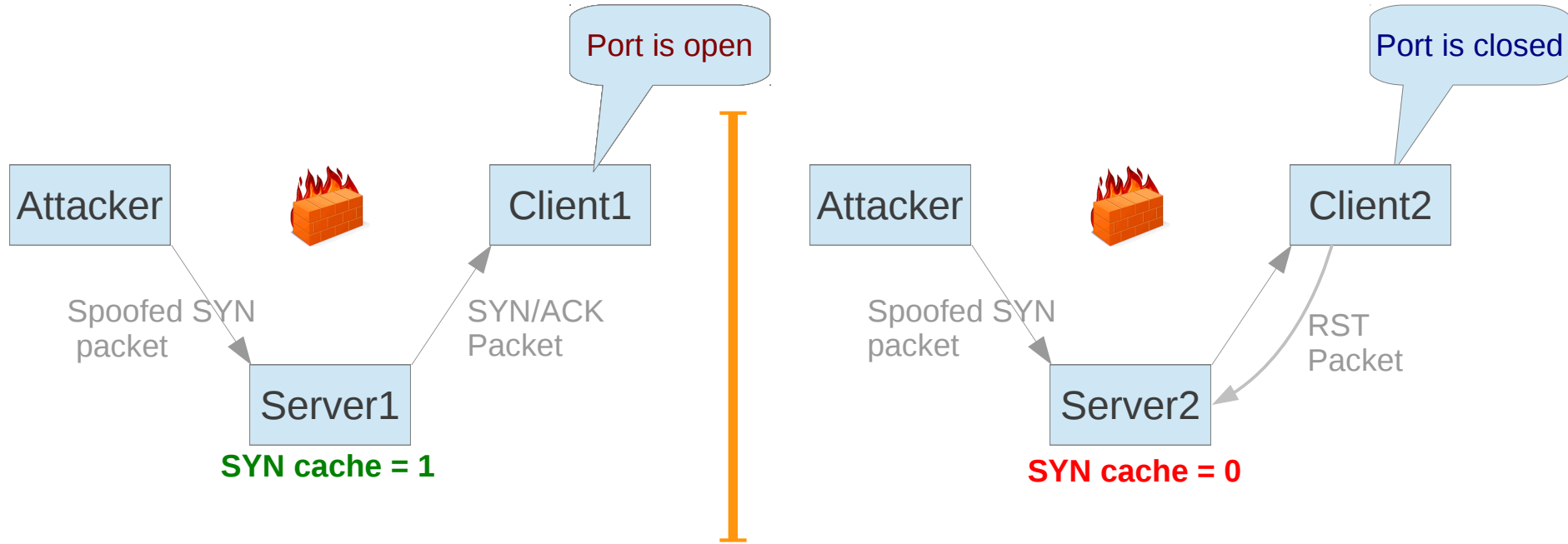
SYN backlog idle scanning



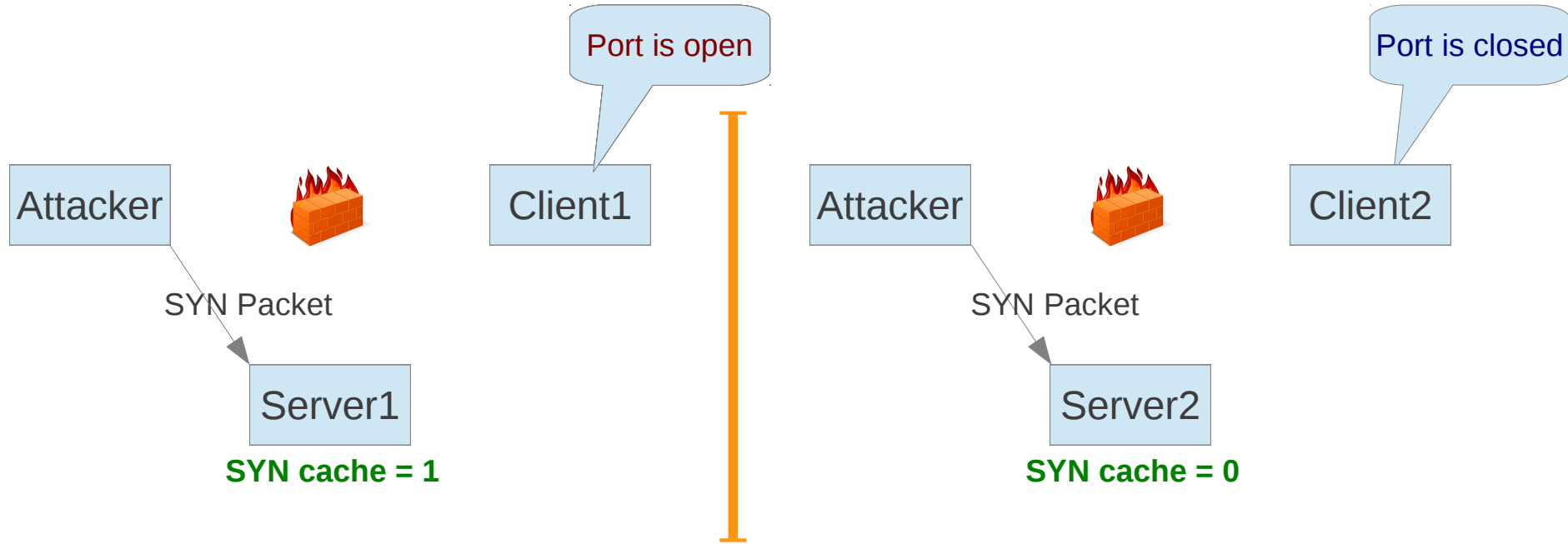
SYN backlog idle scanning



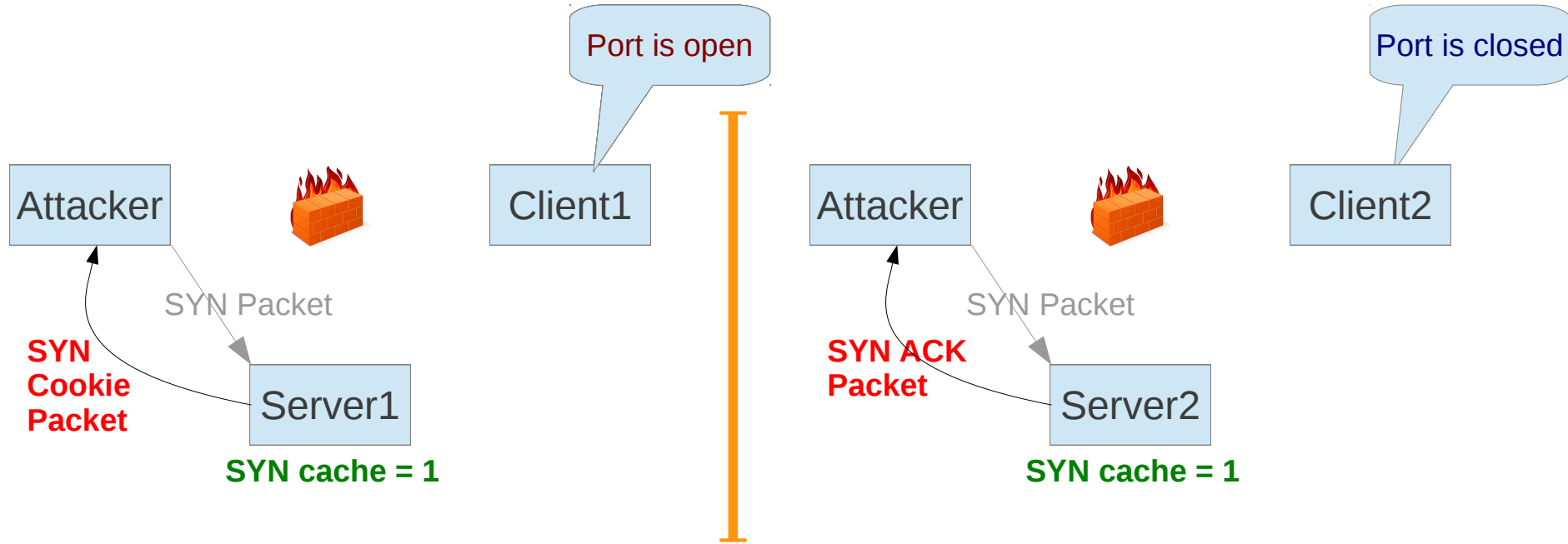
SYN backlog idle scanning



SYN backlog idle scanning



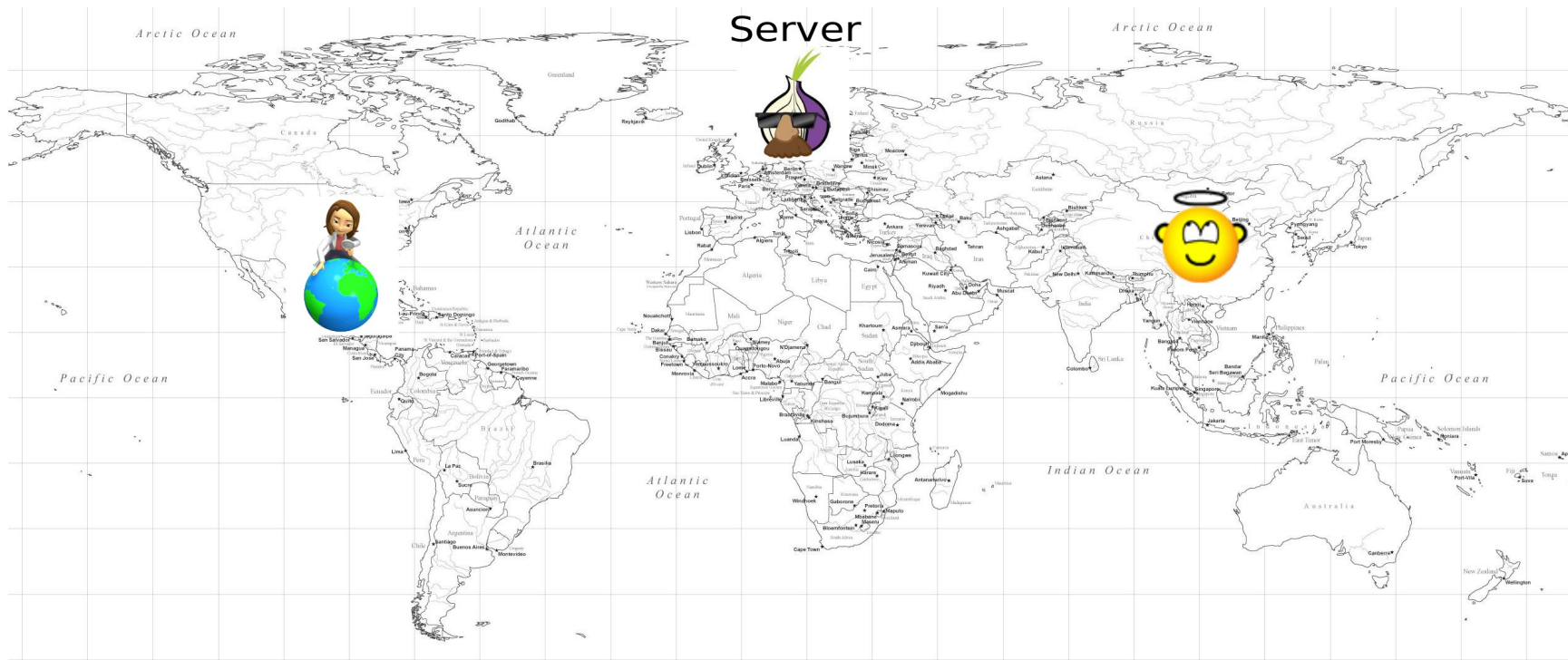
SYN backlog idle scanning



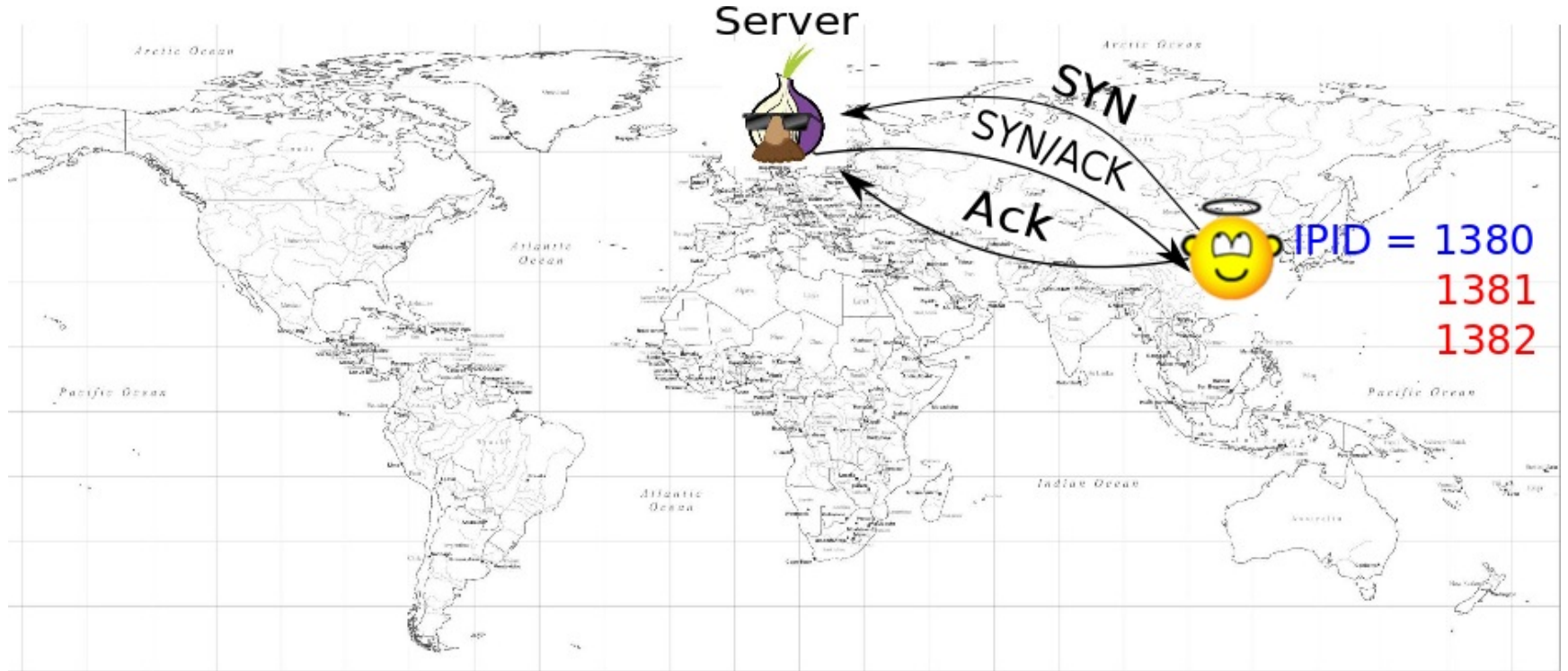
Can we combine idle scans?

- Is there a way that the combination of IPID and SYN backlog idle scan can give us more information?
- Can we use our idle scans to figure intentional packet drops?
 - YES, we can.

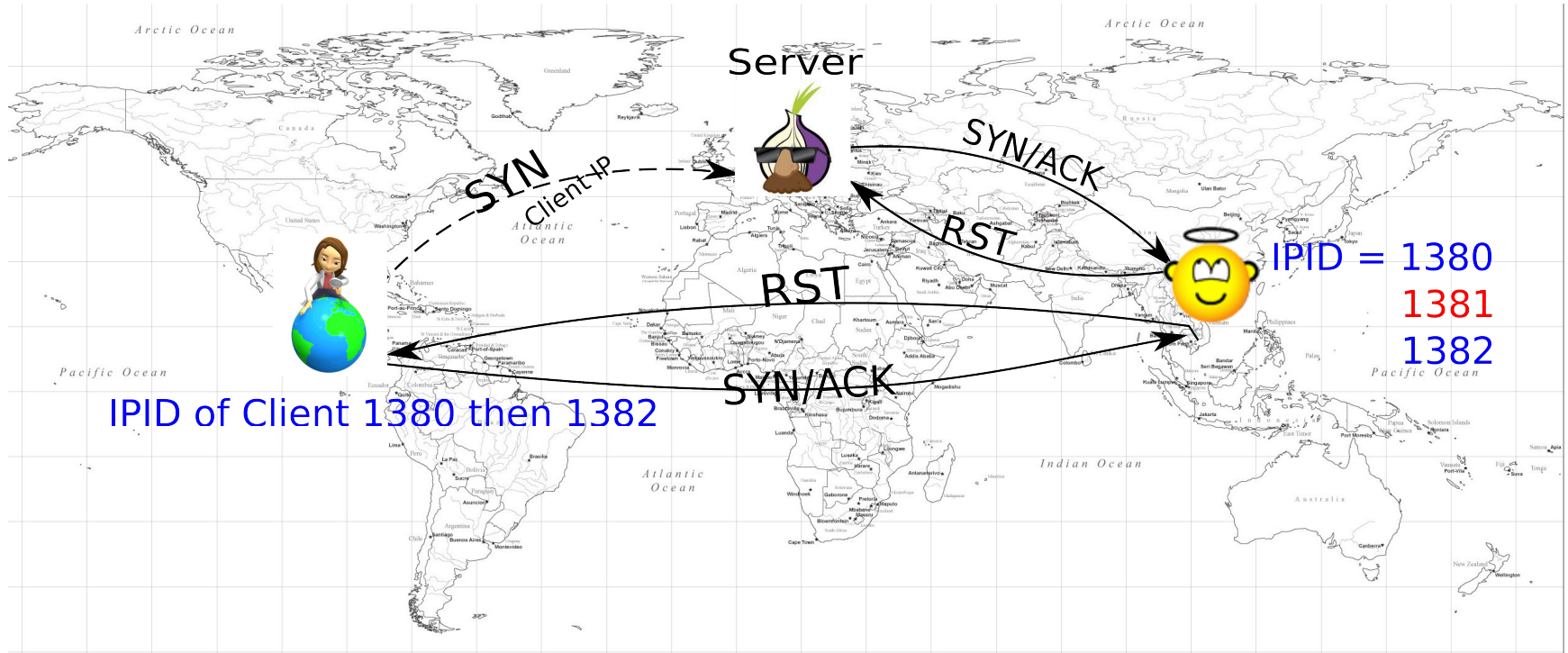
Can we detect censorship?



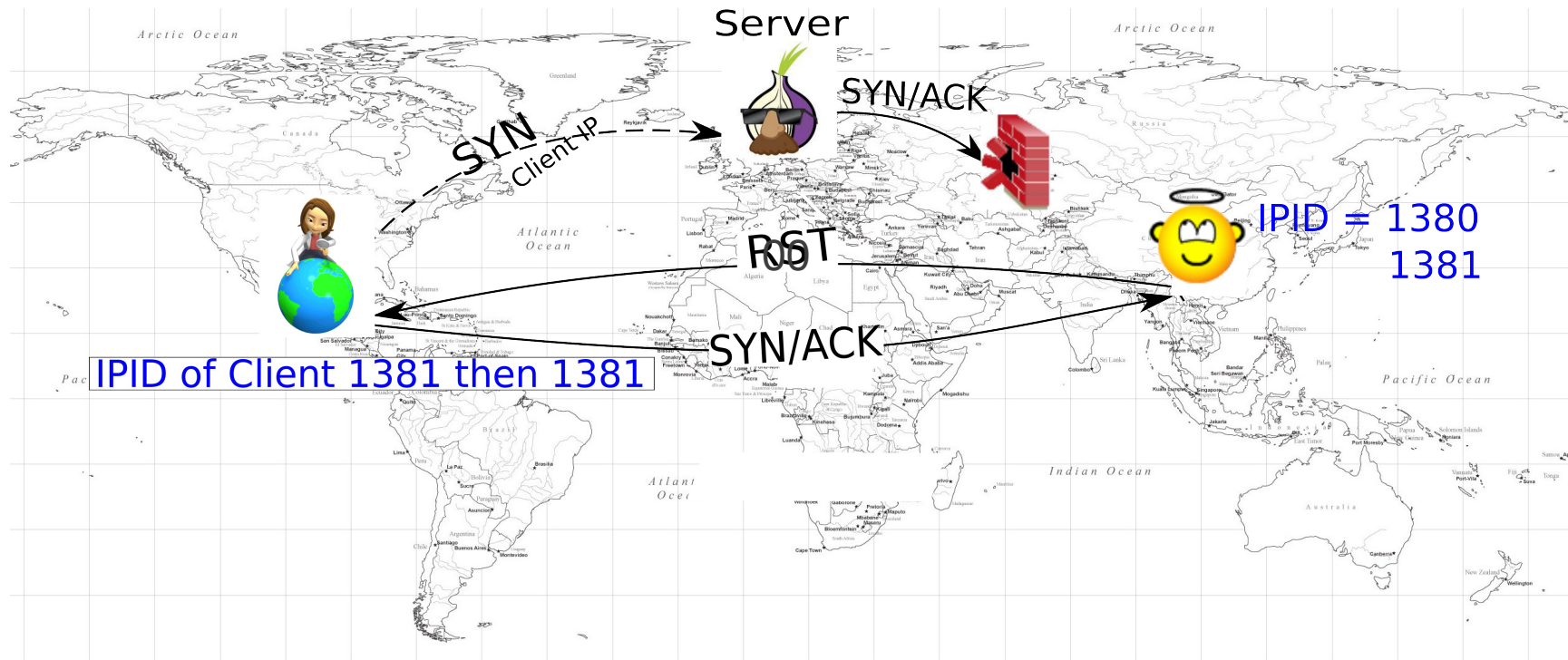
Can we connect to Server?



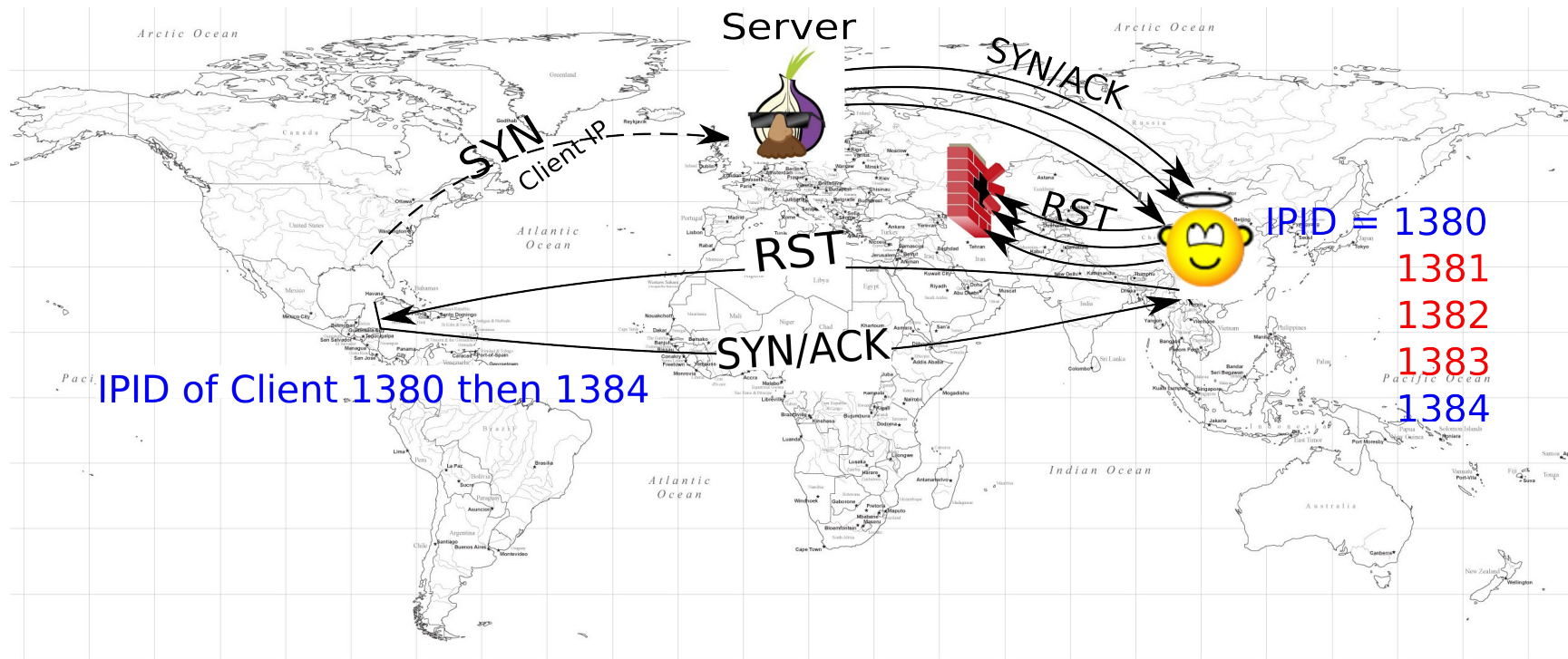
No Direction Blocked



Server to Client Blocked



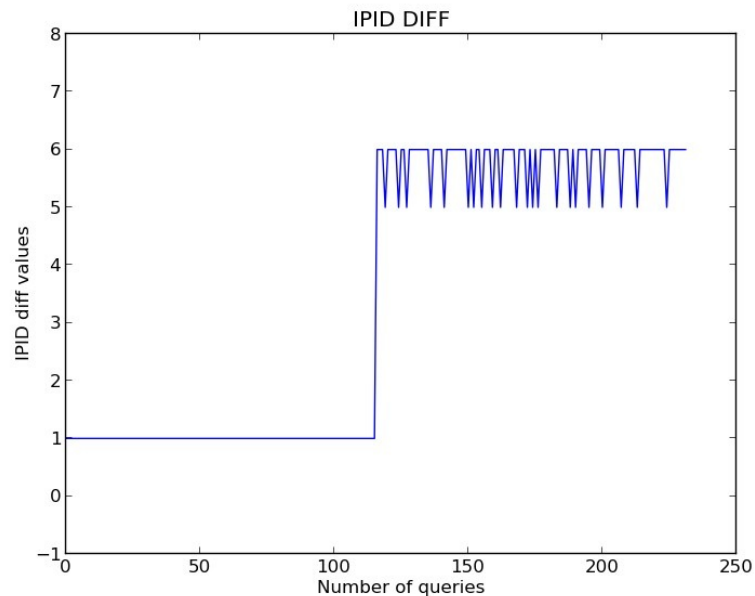
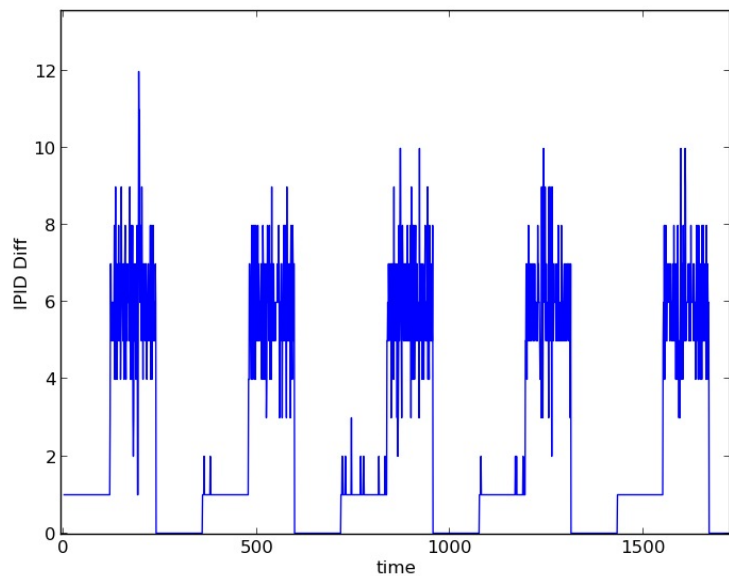
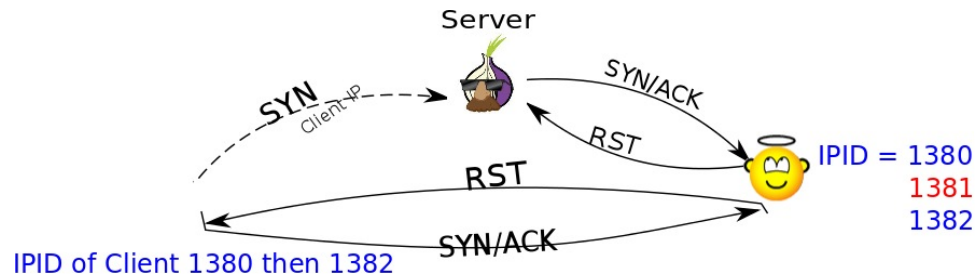
Client to Server Blocked



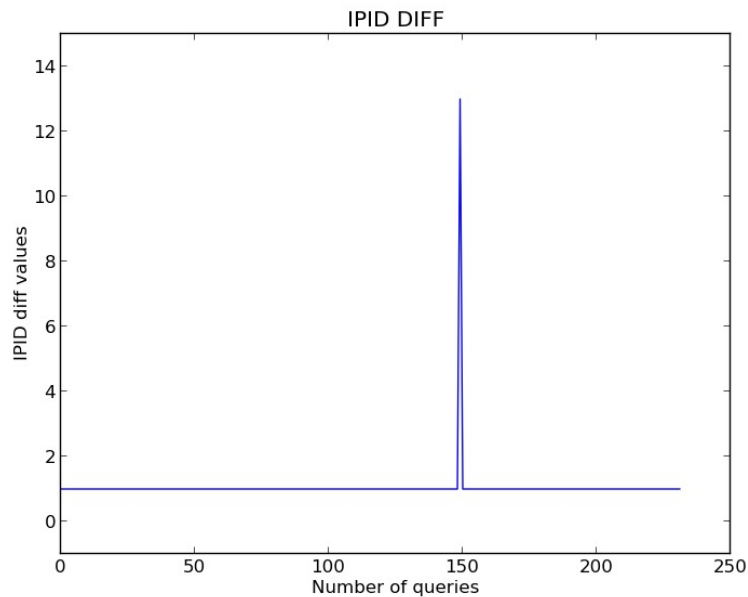
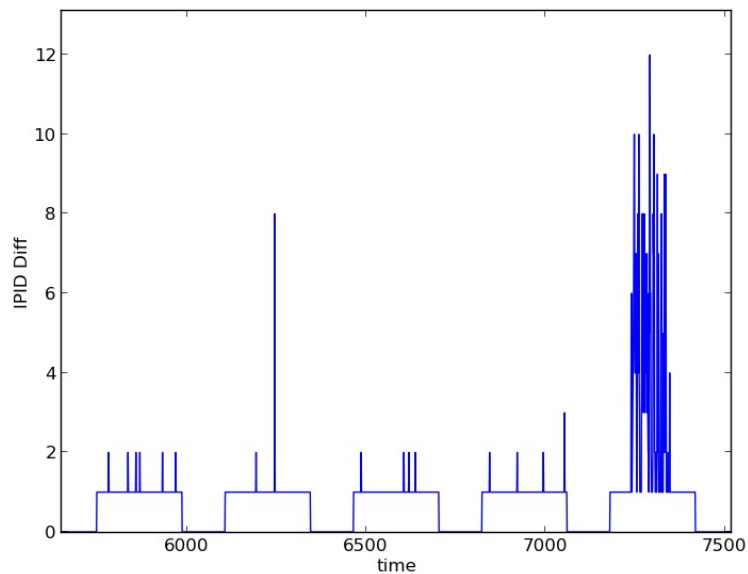
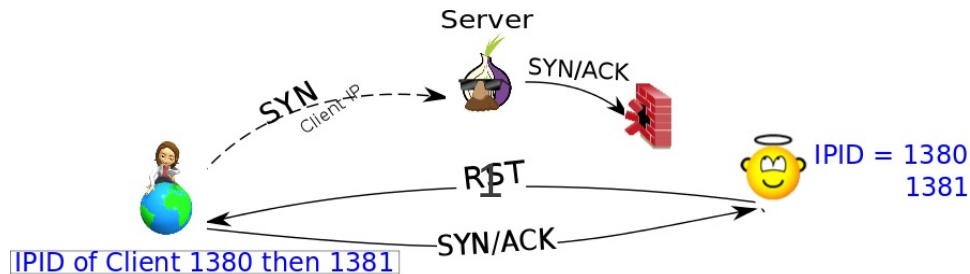
Simple, Effective, Unobtrusive

- Requirements:
 1. A global IPID machine in the area of target
 2. A server IP that has open port and SYN backlog
- Based on our experience, sending 5 spoofed SYN packets for 120 seconds is more than enough to detect different cases.

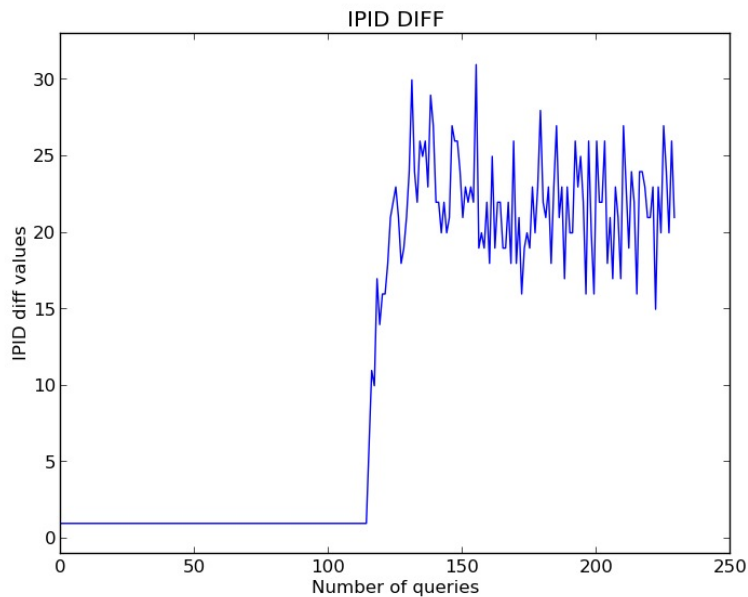
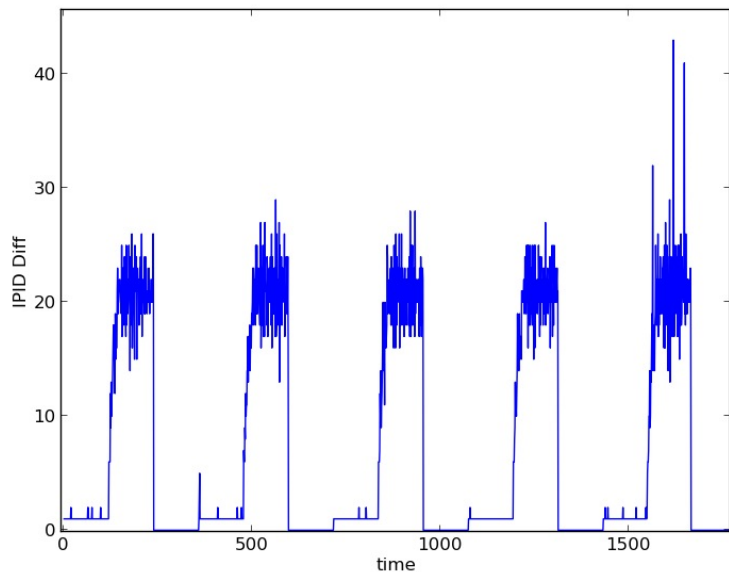
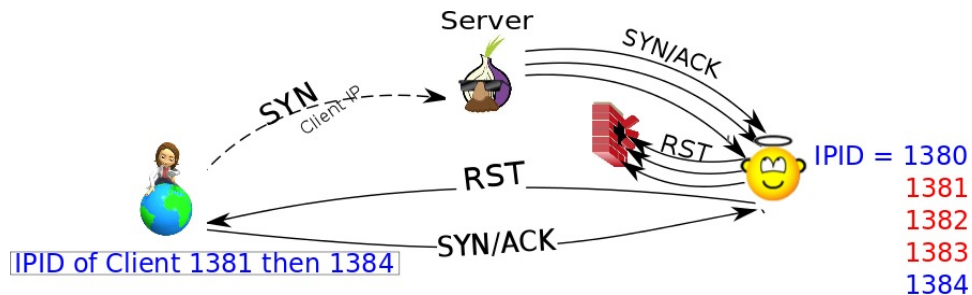
Real Data



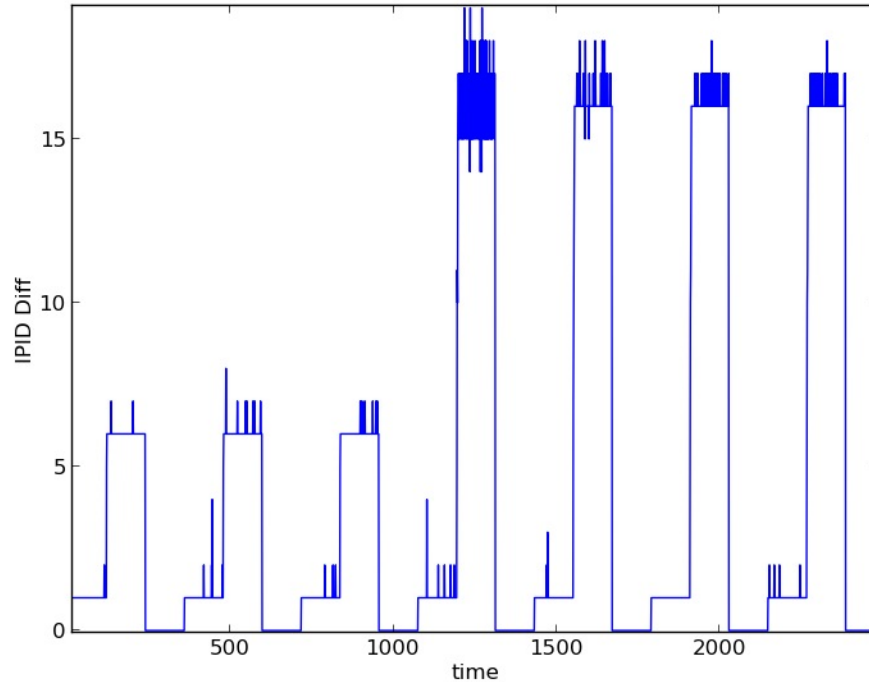
Real Data



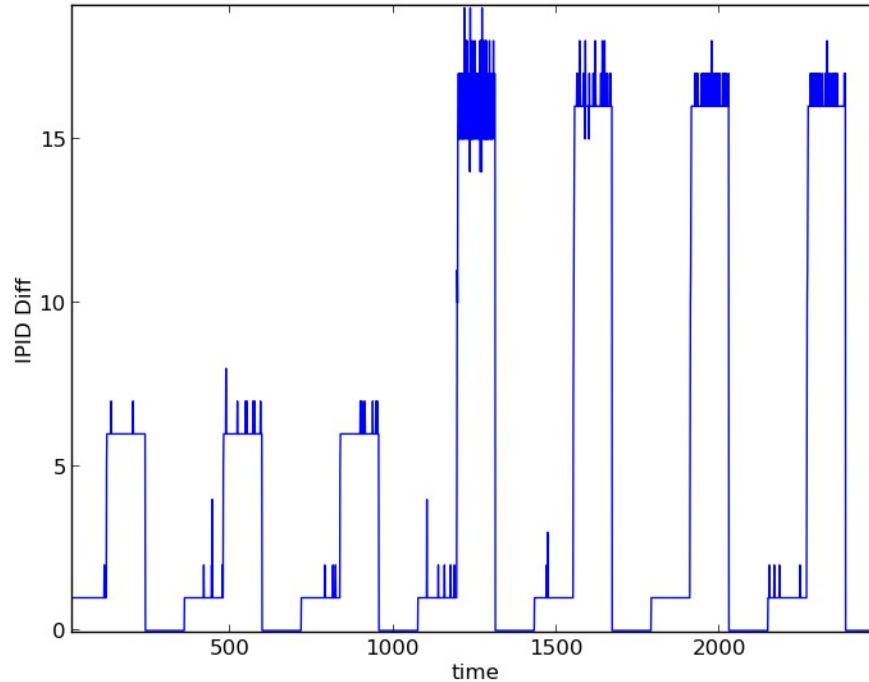
Real Data



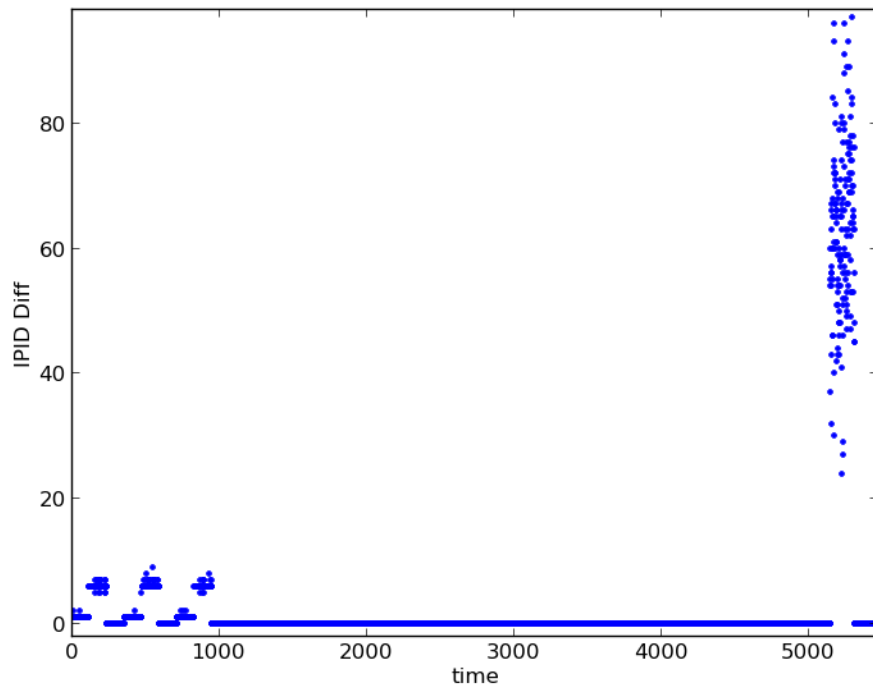
No Direction Blocked Then Client to Server Blocked



No Direction Blocked Then Client to Server Blocked



Global IPID Machine Selection



Future work